

Segurança da Informação

Aula 1

Gilmar Gomes do Nascimento

Instituto Federal do Tocantins
Campus Formoso do Araguaia

24 de agosto de 2026



Catch the flag (Capture a bandeira)



Os desafios em um Capture the Flag geralmente envolvem a descoberta de vulnerabilidades em sistemas operacionais, aplicativos da web, protocolos de rede e outros componentes de TI. Essas vulnerabilidades podem permitir que atacantes comprometam o sistema, obtenham acesso a informações confidenciais ou executem um código malicioso.

- Exploração web
- Criptografia
- Engenharia Reversa
- Forense digital



Lista de CTF

Uma lista de *frameworks*, bibliotecas, recursos, programas e tutoriais. Esta lista colabora com o aprendizado e compartilhamento de informações sobre CTF.

<https://github.com/apsdehal/awesome-ctf>



Introdução ao hacking ético e preparação do ambiente

Compreender a filosofia do hacking ético diferencia profissionais de cibercriminosos. Além disso, a metodologia Capture The Flag (CTF) torna o aprendizado prático e envolvente.



Utiliza as mesmas técnicas e ferramentas de um atacante malicioso, mas com a permissão do proprietário do sistema e com o objetivo de encontrar e reportar as vulnerabilidades para que possam ser corrigidas. É uma atuação proativa que visa fortalecer a segurança antes que os verdadeiros vilões (black hats) apareçam.



Mentalidade ofensiva

Para defender um sistema, não basta apenas construir muros: é preciso também pensar como quem tentaria derrubá-los. É a partir dessa ideia que a metodologia CTF e o hacking ético ajudam a desenvolver a chamada **mentalidade ofensiva**.

- 1 Como isso poderia ser quebrado?
- 2 O que acontece se um dado inesperado for enviado?
- 3 Existe alguma informação que não deveria estar visível?



Open Web Application Security Project (OWASP) é uma comunidade online global e sem fins lucrativos que produz artigos, metodologias, documentação, ferramentas e tecnologias de forma livre e aberta no campo da segurança de aplicações web.



Categorias I

- A01: Controle de acesso quebrado (Broken Access Control)
- A02: Configuração incorreta de segurança (Security Misconfiguration)
- A03: Falhas na cadeia de suprimentos de software (Software Supply Chain Failures)
- A04: Falhas criptográficas (Cryptographic Failures)
- A05: Injeção (Injection)



Categorias II

- A06: Design inseguro (Insecure Design)
- A07: Falhas de autenticação (Authentication Failures)
- A08: Falhas de integridade de software ou dados (Software or Data Integrity Failures)
- A09: Falhas de logs de segurança e alerta (Security Logging and Alerting Failures)
- A10: Manuseio incorreto de condições excepcionais (Mishandling of Exceptional Conditions)



Categorias III

A01: Controle de acesso quebrado (Broken Access Control)

Ocorre quando as restrições sobre o que os usuários autenticados podem fazer não são aplicadas de maneira correta, permitindo-lhes acessar dados ou executar ações fora de suas permissões.

A02: Configuração incorreta de segurança (Security Misconfiguration)

Resulta da falha em implementar todos os controles de segurança necessários para um servidor ou aplicação web ou da implementação incorreta desses controles.



Categorias IV

A03:Falhas na cadeia de suprimentos de software (Software Supply Chain Failures)

Acontece quando um componente de software, biblioteca ou dependência de terceiros é comprometido, introduzindo vulnerabilidades na aplicação.

A04:Falhas criptográficas (Cryptographic Failures)

Relaciona-se a falhas na criptografia (ou à sua ausência), que, com frequência, levam à exposição de dados sensíveis.



Categorias V

A05:Injeção (Injection)

Ocorre quando dados não confiáveis são enviados a um interpretador como parte de um comando ou consulta, enganando-o para executar comandos não intencionais ou acessar dados sem autorização.

A06:Design inseguro (Insecure Design)

É uma categoria ampla e representa diversas fraquezas, expressas como “falta ou ineficácia do controle de design”, indicando que os riscos não foram considerados durante a fase de projeto.



Categorias VI

A07: Falhas de autenticação (Authentication Failures)

acontece quando as funções relacionadas à identidade do usuário, autenticação ou gerenciamento de sessão são implementadas de forma incorreta, permitindo que invasores contornem as proteções.

A08: Falhas de integridade de software ou dados (Software or Data Integrity Failures)

refere-se ao código e à infraestrutura que não protegem contra violações de integridade, como a modificação não autorizada de software ou dados.



Categorias VII

A09: Falhas de logs de segurança e alerta (Security Logging and Alerting Failures)

significa que a falta de registro, o monitoramento ou o alerta adequados permitem que atividades suspeitas passem despercebidas, dificultando a detecção e a resposta a incidentes.

A10: Manuseio incorreto de condições excepcionais (Mishandling of Exceptional Conditions)

ocorre quando uma aplicação não lida de modo adequado com erros ou outras condições excepcionais, o que pode levar a vazamento de informações ou negação de serviço.



O papel do Proxy

Definição técnica

Atua como um intermediário (“Man-in-the-Middle”) entre o navegador e o servidor da aplicação web.

Interceptar

O Proxy permite interceptar, visualizar e modificar requisições e respostas HTTPs em tempo real, antes que cheguem ao destino.



Na unha

O processo de desenvolvimento de código requer técnicas e ferramentas, arcabouços, APIs e diversas bibliotecas, técnicas de PENTEST idem. É possível criar códigos sem ferramentas? sim, contudo costuma ser bem mais complexo e demorado.

- OWASP ZAP
- BURP





Referências Bibliográficas I

-  NTP.br. <https://ntp.br/conteudo/ntp/>. Acessado em: 6 de agosto de 2026.
-  Cisco System, Inc. (2022). Identificar e Solucionar Problemas do Network Time Protocol (NTP). 26 de setembro de 2022.
-  IBM. (2025). Tivoli Application Dependency Discovery Manager. <https://www.ibm.com/docs/pt-br/taddm/7.3.0?topic=problems-synchronization-server>. Acessado em: 6 de agosto de 2026.
-  Cisco. (2025). Use as práticas recomendadas para o Network Time Protocol. https://www.cisco.com/c/pt_br/support/docs/availability/high-availability/19643-ntpm.html. Acessado em: 6 de agosto de 2026.



Referências Bibliográficas II

-  SUSE. (2026). Sincronizando o horário por meio de NTP/NTS.
<https://documentation.suse.com/pt-br/sle-micro/6.1/html/Micro-ntp-time-synchronization/index.html>.
Acessado em: 6 de agosto de 2026.
-  Moreiras, Antonio Marcos. (2021). NTP e NTS de Forma Correta e Segura, Sincronismo de Tempo na Internet. Nic.br.
<https://bibliotecadigital.acervo.nic.br/server/api/core/bitstreams/129d1169-25b5-49ce-b015-28ffadc440da/content>. Acessado em: 6 de agosto de 2026.

